Studio Shodwe

REPORT

WWW.REALLYGREATSITE.COM

Studio Shodwe

VULNERABILITY ASSESSMENT REPORT

Assessment Type : passive web Application vulnerability

Assessed By : S.THAMIZHARASI

Target : http://testphp.vulnweb.com

Course : cyber security

EXECUTIVE SUMMARY

A security assessment was conducted on the live web application testphp.vulnweb.com to identify common web vulnerabilities and misconfigurations.The assessment identified multiple medium and high-risk vulnerabilities, including:

SQL Injection exposure
Missing Security Headers
Insecure Cookies
Information Disclosure
Cross-Site Scripting (XSS)
If exploited, these vulnerabilities could lead to:
Unauthorized data access
Session hijacking
Website defacement
Data breach
Reputation damage
Immediate remediation is strongly recommended.

METHODOLOGY

The vulnerability assessment was conducted using passive scanning techniques. Information was gathered using Nmap and OWASP ZAP to identify security weaknesses, and the findings were analyzed and classified based on risk level (Low, Medium, High).

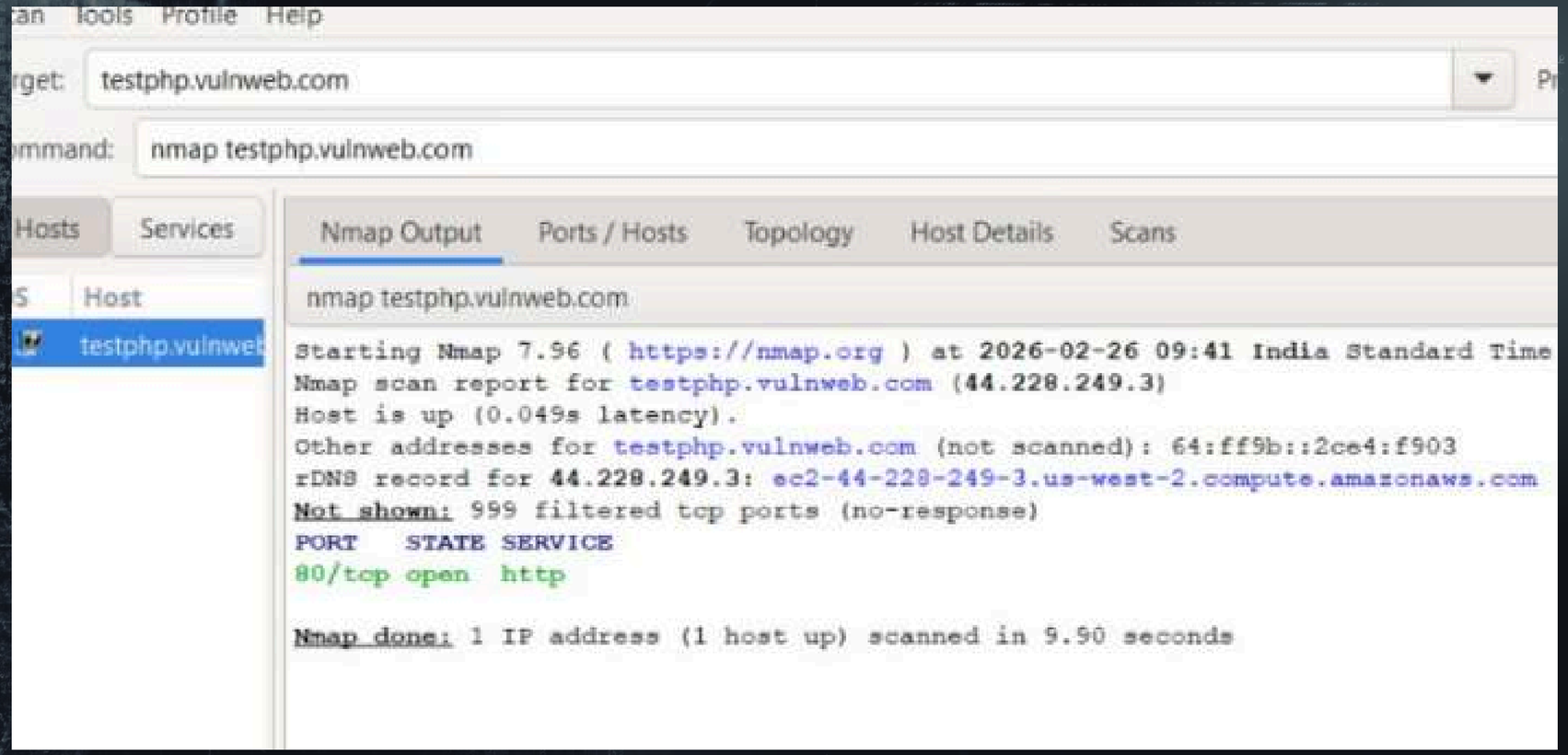
Planning and Scope Definition
Information Gathering
Passive Vulnerability Scanning
Manual Analysis
Risk Classification
Reporting

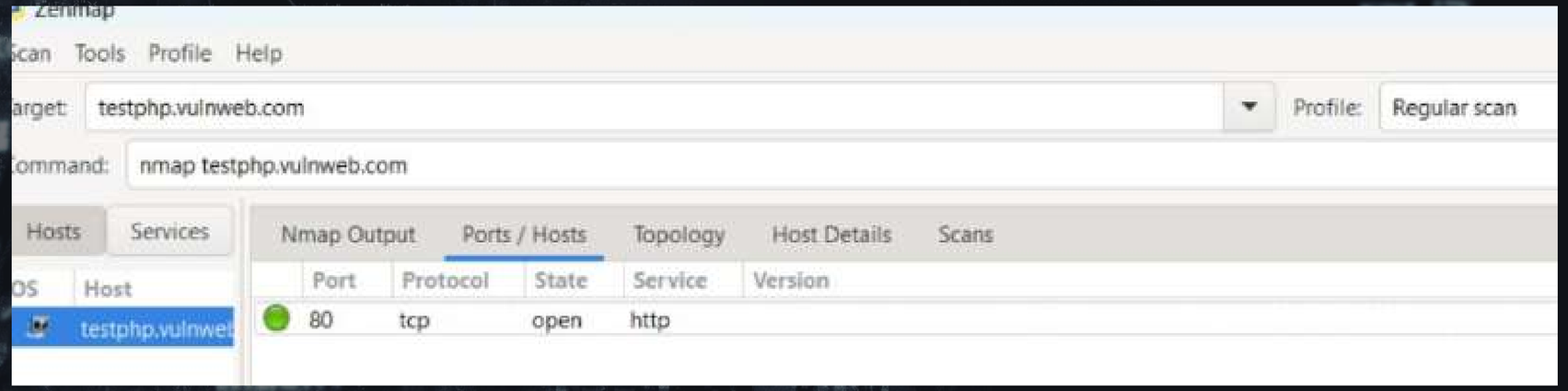
RECONNASIANCE USING NMAP

Reconnaissance using Nmap is the process of scanning a target system to identify open ports, running services, and server details. It helps gather basic information about the target before performing further security analysis.

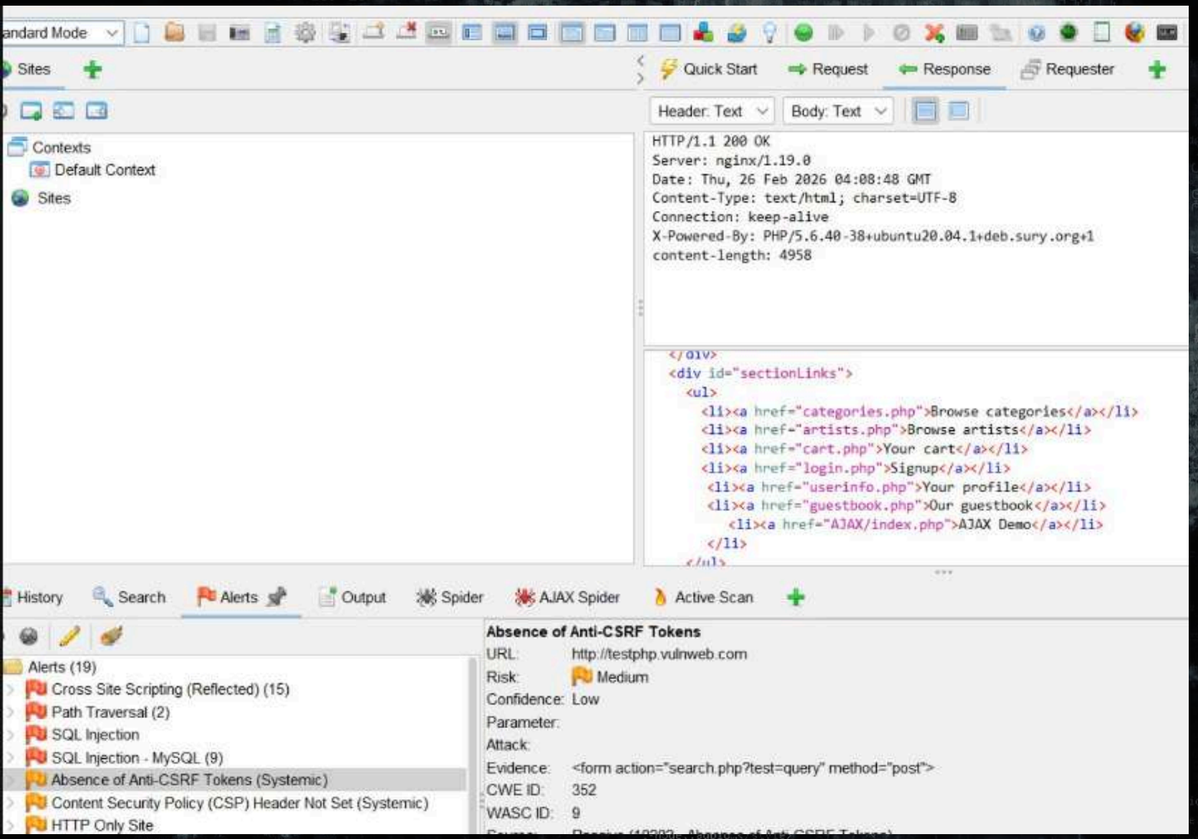
NMAP -SV -T4 TARGETWEBSITE.COM

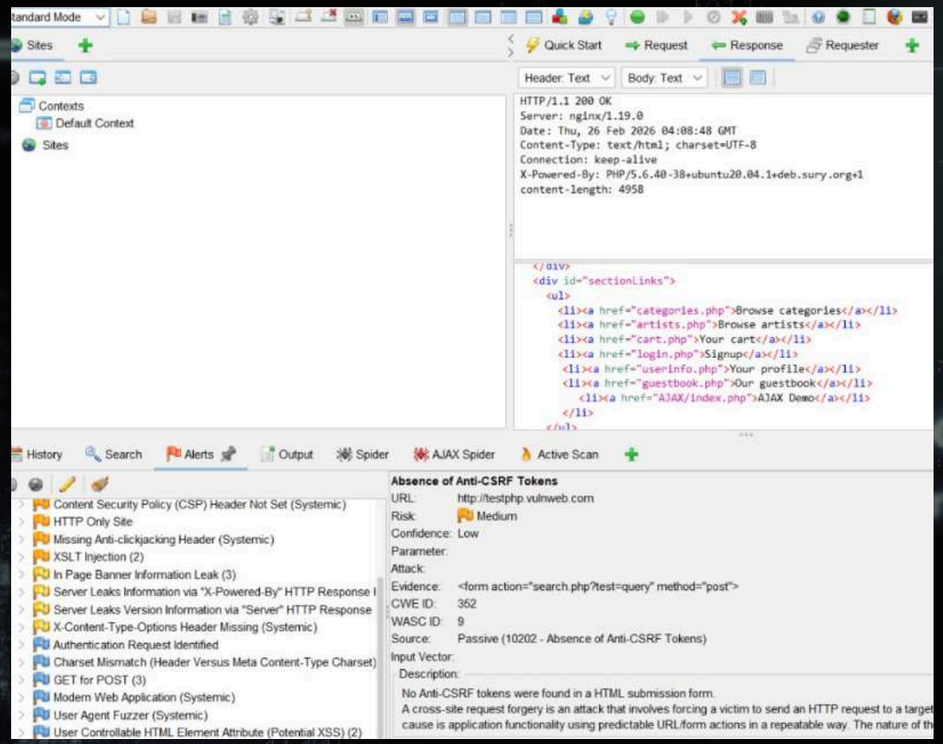
What to look for:
Open ports (80, 443, 21, etc.)
Service versions (Apache, Nginx, MySQL)
Outdated version

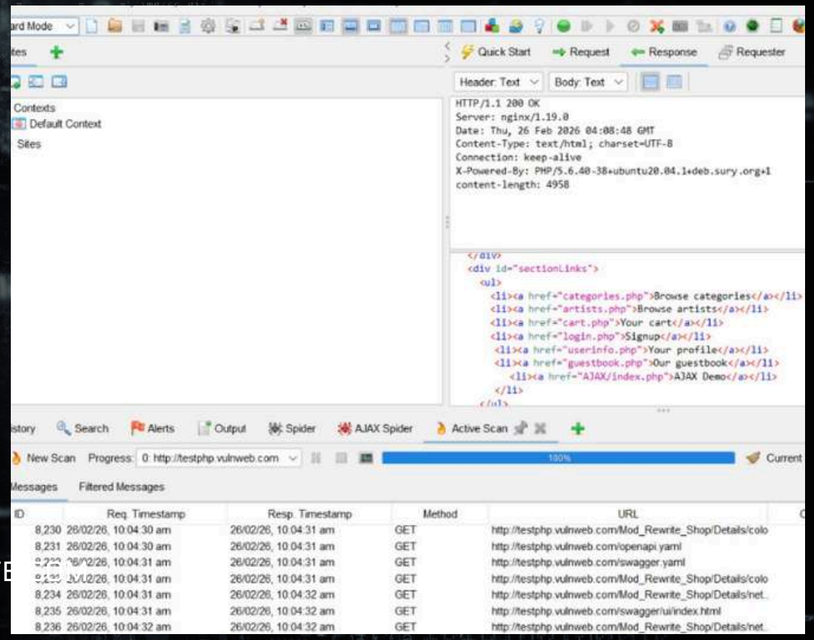




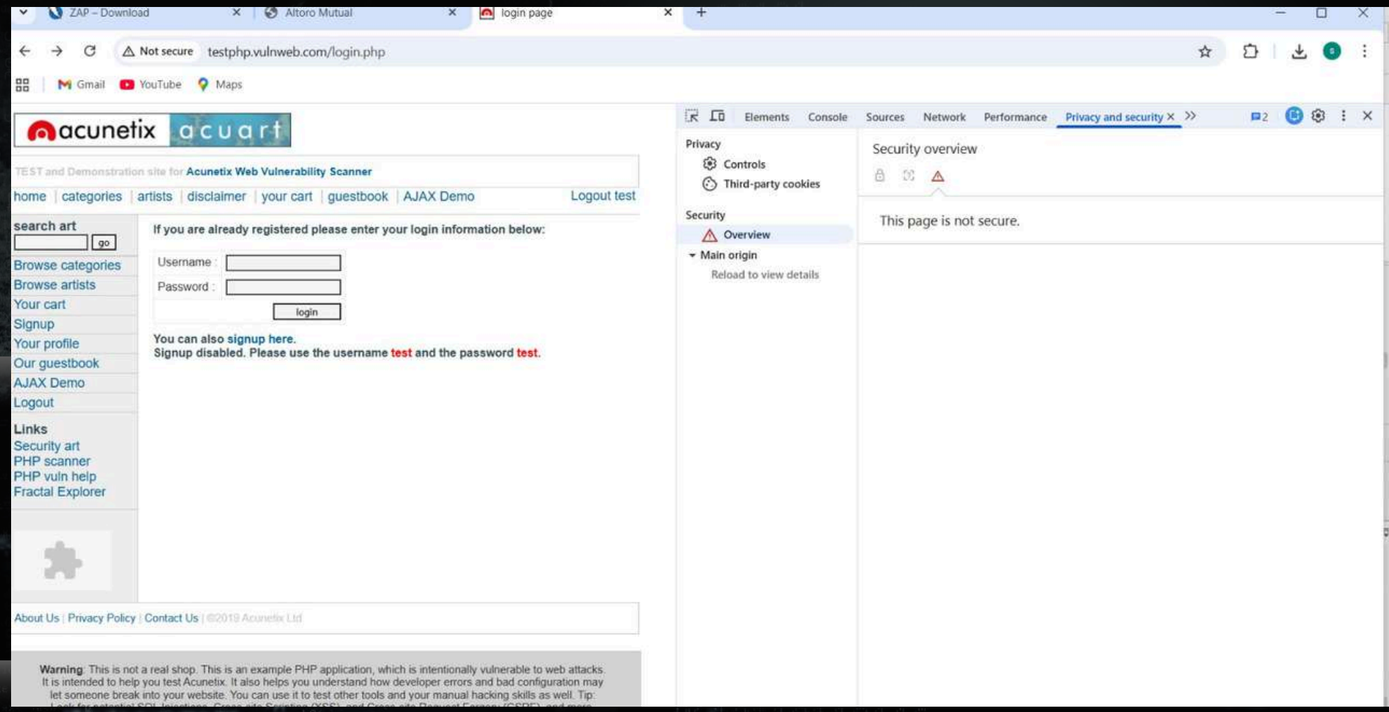
SCAN USING OWASP ZAP (PASSIVE SCAN)







FINDING 1: WEBSITE NOT USING HTTPS



1. VULNERABILITY IDENTIFIED:
   HTTP protocol instead of HTTPS
2. Observation Method:

Using browser Developer Tools (Security and Network tabs), the connection was Marked as “Not Secure,” and the request URL began with Its.

3. Risk Level:
   High Risk
4. Description of the Risk:

Since HTTP does not encrypt data, any information transmitted

5. Possible Threats:
   - Man-in-the-Middle (MITM) attacks
   - Data interception
   - Credential theft
   - Session hijacking
6. Impact:

Sensitive information such as login credentials, personal data, and financial details may be exposed to unauthorized parties.

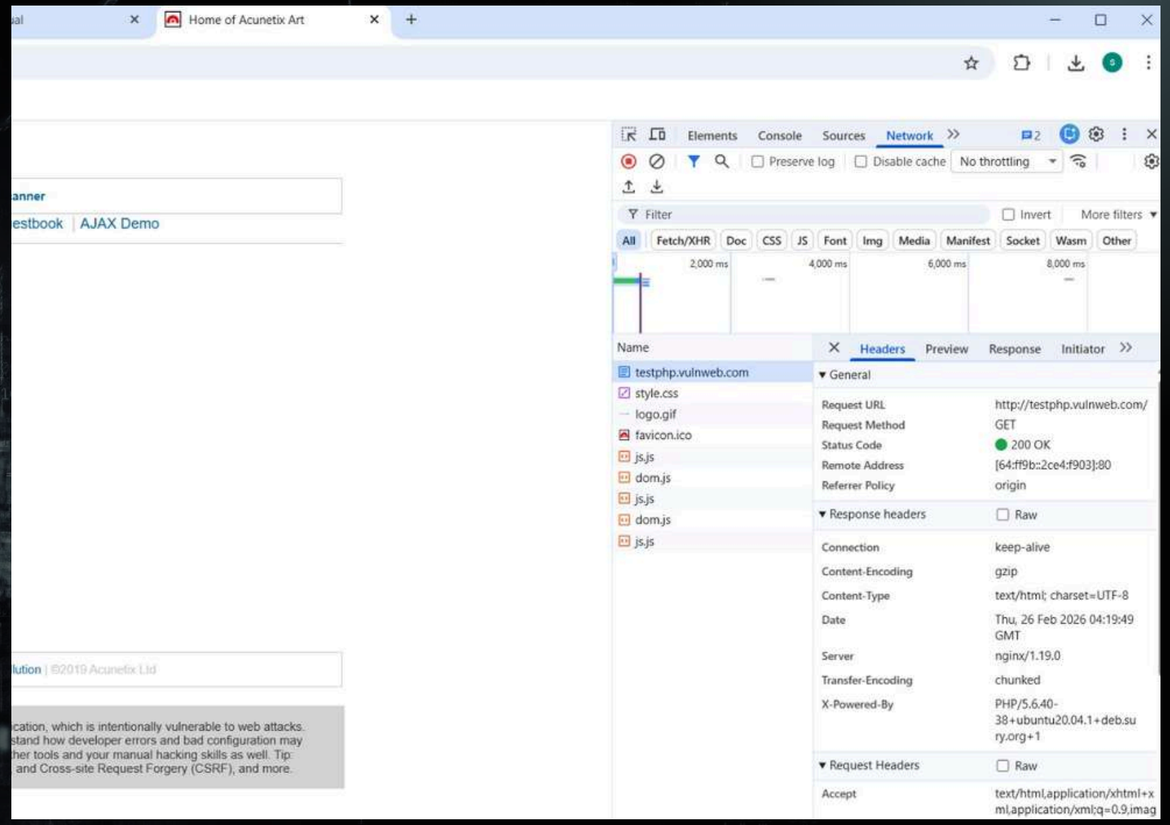
FINDING 2: OUTDATED PHP VERSION (PHP 5.6.40

Description:
PHP version 5.6 reached End of Life in 2018 and no longer receives security updates. Known vulnerabilities in this version can be exploited by attackers.

Possible Threats:
Remote Code Execution (RCE)
SQL Injection
Cross-Site Scripting (XSS)
Full server compromise

Impact:
Attackers may gain unauthorized access to the server, manipulate data, or disrupt services.

Recommendation:
Upgrade to the latest stable version (PHP 8.x) and regularly apply security updates and patches.



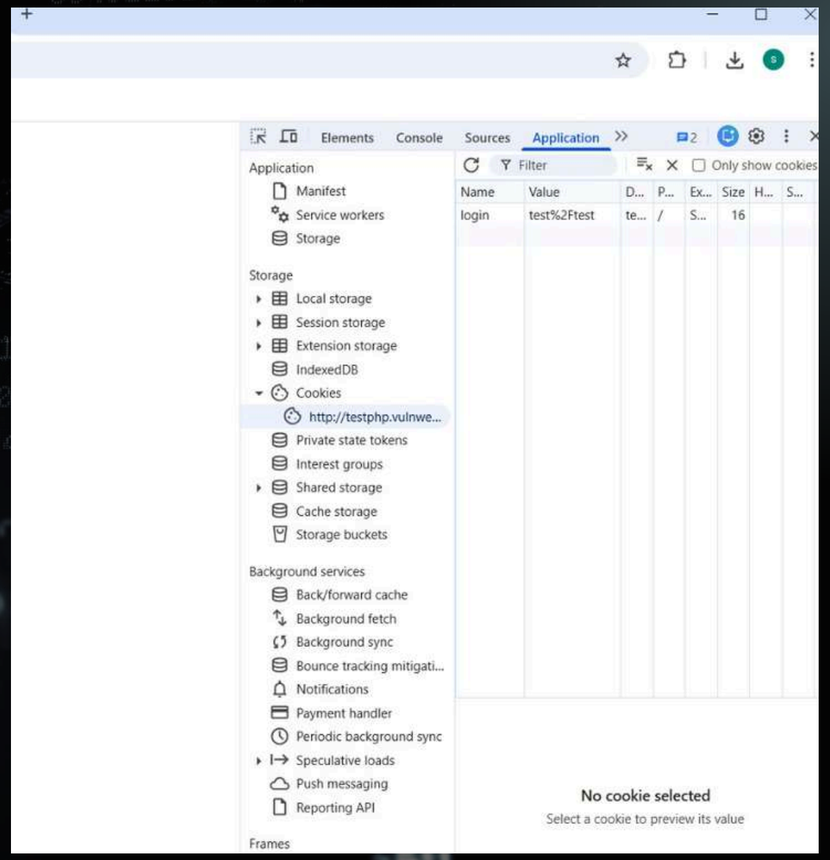
FINDING 3: INSECURE COOKIE CONFIGURATION

Observation Method:

Cookies were analyzed using the Application tab in browser Developer Tools. The cookie attributes were reviewed for security flags.

Secure Flag – Ensures cookies are only sent over HTTPS
HttpOnly Flag – Prevents JavaScript access to cookies
SameSite Attribute – Protects against Cross-Site Request Forgery (CSRF)

impact
Cookie theft via XSS
Credentials exposure
Session hijacking



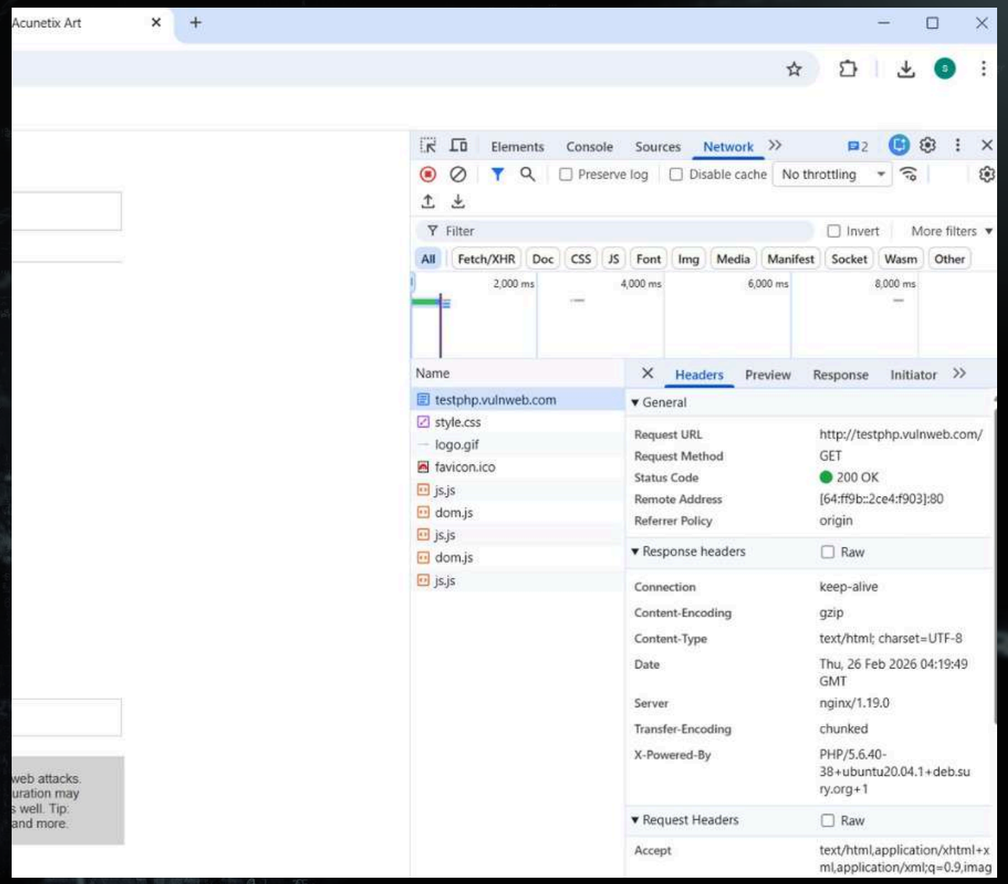
FINDING 4: SERVER VERSION DISCLOSURE

Studio Shodwe

**The server is revealing its exact version.

**Risk Level: Medium

**Why Risky: Attackers can search for known vulnerabilities in nginx 1.19.0
Recommendation: Disable version



RISK CLASSIFICATION CRITERIA

Vulnerability Risk Impact
Outdated PHP 5.6 High Known exploits

Server version disclosure Medium Information leakage

No HTTPS High Data interception
Missing security headers Medium XSS / Clickjacking

CONCLUSION

THE SECURITY ASSESSMENT IDENTIFIED SEVERAL CRITICAL VULNERABILITIES, PARTICULARLY THE ABSENCE OF HTTPS ENCRYPTION AND THE USE OF OUTDATED SERVER TECHNOLOGIES. THESE WEAKNESSES SIGNIFICANTLY INCREASE THE RISK OF DATA INTERCEPTION, SESSION HIJACKING, AND EXPLOITATION OF KNOWN VULNERABILITIES. IMMEDIATE REMEDIATION IS STRONGLY RECOMMENDED TO